

0.1 Introduction to IDS

0.1.1 Definition of IDS

An Intrusion Detection System (IDS) is a security tool designed to detect unauthorized access, malicious activities, or policy violations within a network or computer system. It works by continuously monitoring network traffic, system logs, and application behavior, then alerting security personnel when it detects suspicious activity.

0.1.2 Importance of IDS in cybersecurity

In today's connected digital world, Intrusion Detection Systems have become essential components of organizational security. Their importance can be understood through several key benefits:

- **Early Warning System**

IDS provides real-time monitoring and detection of suspicious activities, which is crucial in today's fast-evolving cyber threat landscape. By analyzing network traffic, it identifies patterns matching known attack signatures or deviations from normal behavior, enabling swift responses. For instance, it can detect a sudden spike in traffic from an unusual IP address, potentially indicating a Distributed Denial-of-Service (DDoS) attack. This early warning reduces the risk of data loss and system compromise, with real-time alerts enhancing incident response times.

- **Part of Layered Security**

Cybersecurity relies on a layered defense strategy, and IDS plays a crucial role within this ecosystem. For example, IDS can complement firewalls by detecting threats that evade primary security measures. While firewalls block unauthorized access based on predefined rules, they might miss sophisticated attacks. IDS fills this gap by analyzing the content of network packets and identifying unusual patterns. Another example of IDS integration is its combination with Security Information and Event Management (SIEM) systems. SIEM collects and correlates data, alerts from various sources, including IDS, to provide a comprehensive view of security events. This integration enhances threat detection and response capabilities, allowing organizations to identify complex attack patterns that may go unnoticed by individual security tools.

- **Regulatory Compliance**

Many industries must follow specific security standards in their region, such as the Payment Card Industry Data Security Standard (PCI-DSS), which re-

quires IDS implementation. Having an IDS helps organizations meet these requirements and avoid penalties. This is especially important in sectors like finance and healthcare, where data breaches can have serious consequences.

- **Monitoring and Analysis**

IDS offers comprehensive monitoring capabilities across the organization infrastructure by combining different approaches to ensure robust security. For example, Network-based IDS (NIDS) focuses on analyzing traffic across the entire organizational network. It is typically deployed at strategic points, such as behind firewalls or at network entry and exit points, to detect suspicious activities like unauthorized access attempts or Distributed Denial-of-Service (DDoS) attacks. On the other hand, Host-based IDS (HIDS) operates at the individual host level, monitoring specific devices such as servers, workstations, or routers. HIDS is particularly effective at detecting unauthorized file modifications, unusual processes, or unexpected system behavior on the host. By integrating both NIDS and HIDS, organizations gain a holistic security view, enabling them to detect threats at both the network and host levels, thereby enhancing their overall defense posture.

- **Alerting and Reporting**

Intrusion Detection Systems (IDS) play a crucial role in cybersecurity by generating alerts and reports that enable proactive threat mitigation. These alerts notify security teams of potential breaches, allowing for swift responses to minimize damage. A notable example is the 2022 Shields Health Care Group breach, where a delayed IDS alert contributed to the exposure of 2 million patients' data, underscoring the importance of timely detection. IDS logs also support event correlation, network forensics, and compliance audits, strengthening incident response and digital investigations. Effective alerting and reporting enhance an organization's ability to detect, analyze, and respond to security incidents efficiently.

0.1.3 General architecture of an IDS

A typical IDS has three main components:

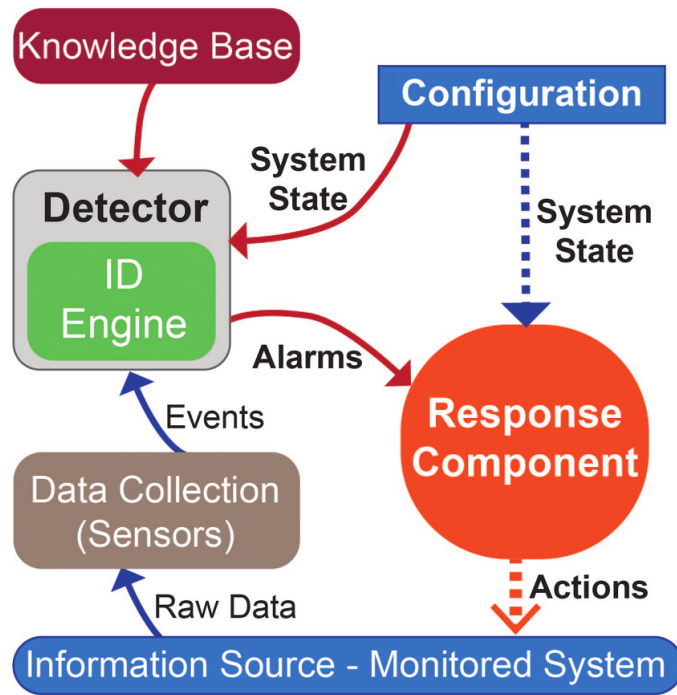


Figure 0.1: General Architecture of an IDS

- **Sensors or Agents:** These components collect data from various sources such as network traffic, system logs, or application activities. *Monitored network nodes are typically referred to as sensors, while monitored endpoint devices such as laptops are commonly referred to as agents.*
- **Analysis Engine:** This component processes the collected data using detection methods to identify potential security threats.
- **Response System:** Once a threat is detected, this component generates alerts and reports for the security team to take action.

0.2 Types of ID

IDSs are categorized based on their placement within a system or the types of activities they monitor:

0.2.1 Network-based IDS (NIDS)

A Network-based Intrusion Detection System (NIDS) monitors traffic across an entire network, analyzing data packets or copies of them for suspicious activity.

a, Placement

NIDS is strategically deployed at critical locations within the network to enhance visibility and threat detection. Key placement points include:

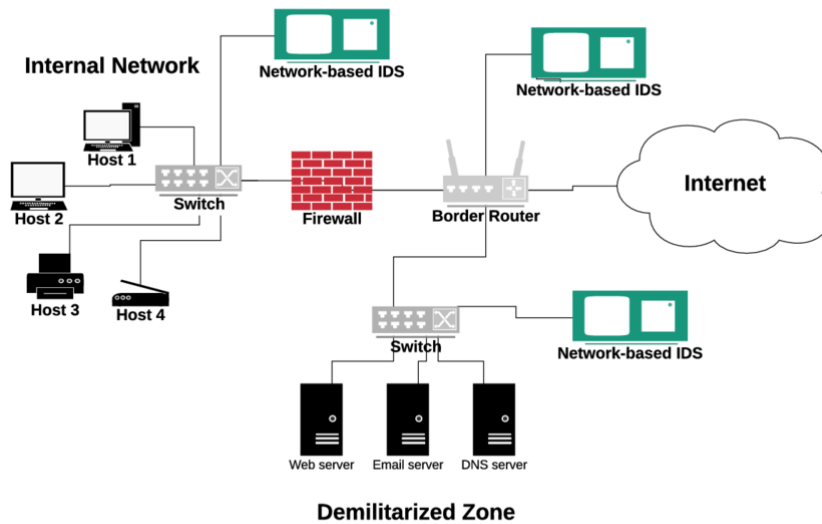


Figure 0.2: NIDS placement within a network

- Behind firewalls behind firewalls: Allowing them to flag malicious traffic that penetrates initial defenses.
- Between different network segments: Monitor lateral movement within the network, detecting potential insider threats or compromised hosts.
- At network entry and exit points: Observes inbound and outbound traffic between subnets, identifying unauthorized external communications or data ex-filtration attempts.

To maintain network performance, a NIDS is typically deployed out-of-band, meaning that network traffic does not flow directly through it. Instead, the NIDS analyzes copies of network packets rather than intercepting the original packets themselves. In enterprise environments, this is commonly achieved using a feature called SPAN (Switched Port Analyzer), also known as Port Mirroring. This feature on network switches allows traffic from one or more source ports to be mirrored to a designated destination port — the SPAN port — which is typically connected to a monitoring device such as an IDS. This configuration ensures that legitimate traffic flows without delay while the NIDS can still identify and flag malicious activity.

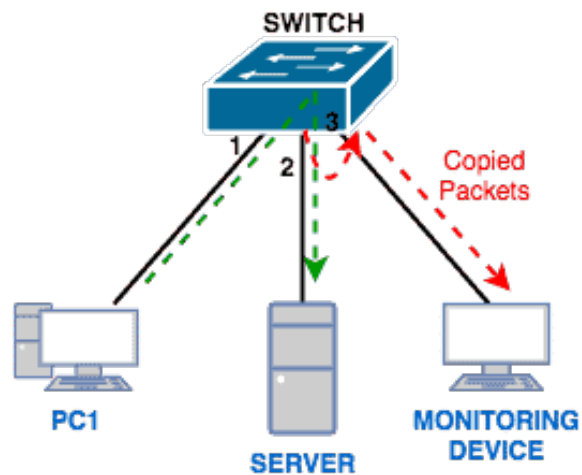


Figure 0.3: Port Mirroring (SPAN) on Switch

b, What NIDS does

NIDS can help protect the entire network by monitoring network traffic for malicious activity. They analyze packets for signs associated with a wide range of hostile or unwanted behaviors, including:

- Malware command and control
- Exploitation tools
- Scanning
- Data exfiltration
- Contact with phishing sites
- Corporate policy violations

c, How NIDS works

1. **Traffic Mirroring:** NIDS does not sit in-line with network traffic, but instead operates out-of-band. This is typically achieved using techniques such as:
 - **SPAN (Switched Port Analyzer) / Port Mirroring:** Copies traffic from one or more switch ports to a designated monitoring port.
 - **Network TAP (Test Access Point):** Hardware device that splits network traffic for monitoring purposes without affecting performance.
2. **Packet Capture:** NIDS sensors capture copies of network packets in real time. These packets are parsed, decoded, and analyzed against a set of detection rules and signatures.

NIDS Data Sources	Examples
Network traffic (packet data)	HTTP, DNS, SMB, FTP, etc.
Packet headers	IP, TCP/UDP, port numbers, flags
Payload content	Command and control strings, exploit signatures
Network flow metadata	Flow direction, duration, byte count

Table 1: Main data sources for NIDS

3. **Analysis and Detection:** After capturing the network packets, the system extracts relevant information such as headers, payloads, and metadata. This data is then passed to the detection engine for analysis. The inner workings of the detection engine, including techniques such as signature-based and anomaly-based detection, will be discussed in a later section of this report.
4. **Alerting and Logging:** Once suspicious activity is detected, NIDS logs the event and generates alerts for the security operations team. Integration with SIEM platforms allows for centralized analysis and correlation.

Some common network-based IDS can be named as: Snort, Suricata, Zeek, Security Onion, etc.

0.2.2 Host-based IDS (HIDS)

Not all malicious activities generate detectable network traffic, meaning a NIDS might not see these certain threats. For example, local attacks like privilege escalation or file tampering often leave no network trace. This is why Host-based Intrusion Detection Systems was .

A Host-based Intrusion Detection System (HIDS) is deployed on individual endpoints such as computers, servers, or routers to monitor local activity and detect potential security threats. Unlike Network-based IDS (NIDS), which observes network-wide traffic, HIDS focuses exclusively on the host system, analyzing incoming and outgoing traffic, file system changes, system logs, and resource usage.

a, What HIDS does

Key monitoring functions of HIDS include:

- File integrity monitoring: Detects unauthorized modifications to critical system files, configuration settings, and script additions.
- Process and application monitoring; Identifies suspicious or unauthorized programs running on the host, e.g., malware execution
- Login anomaly detection: Flags unusual authentication attempts, such as brute-

force login attempts or logins from unexpected locations.

- Behavioral analysis: Observes deviations from normal system behavior that may indicate compromise.

b, How HIDS works

1. **Agent Installation:** HIDS typically requires the installation of an agent on each machine that needs to be monitored.
2. **Data Collection and Transmission:** The agent on each host collects data from the following system sources and sends it to a central processing node:

HIDS Data Sources	Examples
Application and system logs	/var/log/, Windows Event Logs
Windows Registry	Sensitive changes
System performance	Abnormal CPU, RAM usage
File system status	Unauthorized file modifications or creations

Table 2: Main data sources for HIDS

Additionally, HIDS typically operates by taking periodic snapshots of critical system files and comparing checksum over time to detect unauthorized changes.

3. **Analysis and Alerts:** The central node uses detection engines (similar to NIDS) to analyze the data and trigger alerts for the security team to investigate when suspicious activity is detected.

By providing in-depth visibility into host activities, HIDS enhances endpoint security, aiding in threat detection, forensic analysis, and compliance enforcement.

Deploying HIDS in large environments is complex because:

- It requires managing many agents across multiple hosts.
- Manual configuration is required to properly monitor specific applications — many default applications may be overlooked.

Solution: Using automation tools like **Ansible** for auto deployment, configuration, and management of HIDS agents. In reality, without automation, deploying and maintaining HIDS for each individual container would be infeasible.

Some common host-based IDS can be named as: Wazuh, OSSEC, Tripwire, Sagan etc.

c, Different between NIDS and HIDS

The figure below illustrates different deployment locations of NIDS and HIDS within a network infrastructure.

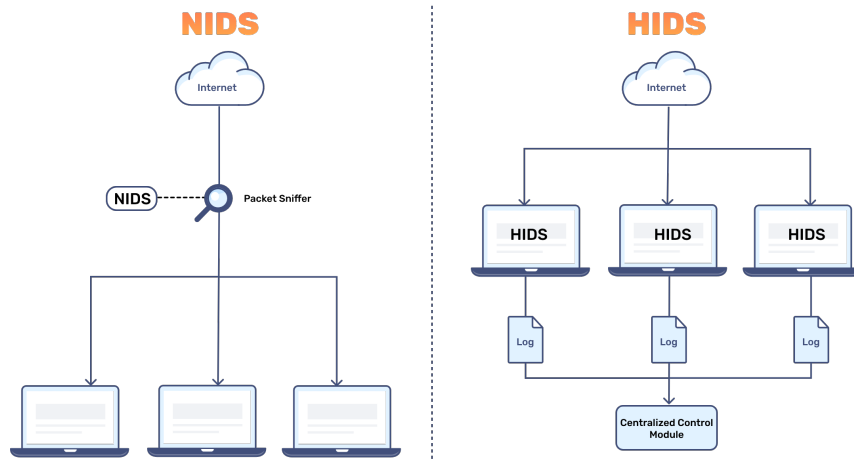


Figure 0.4: NIDS (left) vs. HIDS (right)

To better understand their differences in functionality and deployment, Table 3 provides a comparative analysis of NIDS and HIDS in terms of key features such as scope, installation, detection methods, and response time.

Table 3: Comparison Between Network-based IDS (NIDS) and Host-based IDS (HIDS)
[1]

Feature	NIDS (Network-based IDS)	HIDS (Host-based IDS)
Coverage	Monitors traffic across the entire network (wide scope)	Monitors activity on a specific host (narrow scope)
Installation	Deployed at strategic network locations; often on a dedicated server connect to switch' SPAN port	Installed on many individual endpoints; using automation tools to setup on devices
Cost	Generally more expensive due to additional infrastructure and maintenance needs	More cost-effective as it operates on individual systems
Data Source	Analyzes network traffic, including packet headers and payloads. Inspects network packets for anomalies and attack signatures	Relies on system logs, file integrity monitoring, and process analysis
Response Time	Provides real-time alerts upon detecting suspicious network activity	Detects attacks post-execution, generating alerts after system changes occur
OS Dependency	Operating system independent	OS-dependent, tailored to the host system's architecture
Attack Assessment	Focuses on attack attempts and network-based threat detection	Evaluates the success and impact of attacks on the host
Visibility into encrypted	No	Yes (at host)
Impact on host performance	No	Potentially high

0.2.3 Hybrid IDS

Hybrid Intrusion Detection Systems (Hybrid IDS) integrate multiple intrusion detection approaches, typically combining Network-based IDS (NIDS) and Host-based IDS (HIDS), to provide a more comprehensive security solution.

While NIDS monitors network traffic for suspicious activity across multiple hosts, HIDS provides granular monitoring of specific devices, including file integrity checks and log analysis. This dual-layered approach enhances detection accuracy and mitigates blind spots inherent in standalone NIDS or HIDS implementations.

For example, NIDS can detect unusual network behavior, such as repeated failed login attempts from an external source, while HIDS can verify whether those attempts resulted in unauthorized access to a critical system. Additionally, HIDS

can identify malware propagation from a compromised machine, complementing NIDS by providing endpoint-level insights.

Hybrid IDS solutions are generally more robust than single-method detection systems, leveraging both signature-based and anomaly-based detection techniques.

0.2.4 Other Specialized IDS Types

In addition to NIDS, HIDS, and Hybrid IDS, several specialized IDS types exist to address unique security concerns that less commonly used:

- **Protocol-based IDS (PIDS):** Monitor communication protocols (e.g., HTTP, HTTPS) to detect protocol anomalies or attacks. It is commonly deployed on web servers to identify malicious HTTP requests, such as SQL injection attempts. With HTTPS protocol, it requires placement at the point where encrypted traffic is decrypted to analyze HTTPS connections effectively.
- **Application Protocol-based IDS (APIDS):** Operate at the application layer to monitor application-specific protocols. Typically placed between critical components, such as a web server and an SQL database, to detect anomalies like unauthorized SQL queries. This type of IDS is useful in preventing attacks such as SQL injection and API exploitation

0.3 Detection Methods

IDSs can be deployed as software applications, dedicated hardware appliances, or cloud-based services. They primarily use two core detection methodologies:

a, Signature-based detection

Signature-based detection, also known as Rule-based detection or Misuse Detection[2], relies on predefined signatures—unique patterns representing known attack behaviors. IDS scans network traffic for matches against these signatures and triggers alerts upon detection.

- **Advantages:**
 - Highly effective against known threats.
 - Low false positive rate when signatures are well defined.
- **Disadvantages:**
 - It is challenging to build a rule set that is flexible enough to reliably detect malicious traffic, while avoiding false positives from legitimate applications that may exhibit similar behavior. This process requires an experienced administrator, careful tuning of the IDS to match the specific characteristics of the network it is monitoring, as well as regular audits

consistently applied.

- The effectiveness of signature-based detection depends heavily on frequent updates to the signature database with the latest threat intelligence. As new cyber attacks appear and known attack methods evolve, the system must be updated regularly. A major limitation of this approach is that it cannot detect unknown (zero-day) attacks that have not yet been analyzed and included in the signature database.

Signature-based systems identify characteristic patterns derived from statistical analyses. These signatures do not need to match 100 percent, as security professionals aim to create signatures with high generalization capabilities that can detect attacks even with minor modifications

0.3.1 Anomaly-based detection

On the other hand, Anomaly-based IDS, also known as “Behavior-based Detection” [2], depend on identifying patterns. With advances in artificial intelligence and particularly machine learning, deep learning in recently years, anomaly-based detection has become increasingly sophisticated and widely adopted. This method employs machine learning or deep learning algorithms to establish and continuously refine a baseline model of normal network activity. The system then compares ongoing network activity against this model, flagging deviations such as processes consuming abnormal bandwidth or devices opening unexpected ports. For more specific, the workflow is:

1. Establish a baseline of normal network behavior
2. Flag activities that deviate from this normal pattern
3. Detect potentially unknown threats, including zero-day exploits

This modern method offers several advantages over traditional signature-based detection, including:

- **Advantages:**

- **Detection of Unknown Threats:** Ability to detect previously unknown threats that might evade signature-based detection, including zero-day exploits—attacks that exploit software vulnerabilities before developers become aware of them or implement patches.
- **Adaptability:** Anomaly-based systems can adapt to changing network environments and evolving attack techniques, making them more resilient against sophisticated threats.

- **Disadvantages:**

May generate more false positives than signature-based approaches. Even legitimate activities, such as authorized users accessing sensitive resources for the first time, might trigger alerts in an anomaly-based system.

Another problem with Heuristic-based IDS, a type of anomaly detection, which focuses on unusual activities and atypical user behaviors. For sophisticated intrusion attempts, individual malicious actions may appear normal and not raise any suspicion. However, when these actions are combined in a specific sequence, they can indicate an ongoing attack. In such cases, a system might gradually fall/manipulated under the control of an intruder through a series of seemingly legitimate operations. To address this issue, engineers developed a tool which is called **inference engines**, which link multiple suspicious actions into a coherent pattern. These engines can operate using one of two fundamental principles: state-based detection or model-based detection. We will not go into the details of these principles here, but the general idea is to detect suspicious behavior sequences that could potentially lead system to an unsafe state [3].

Despite significant improvements in AI-driven detection, anomaly-based IDS still require careful tuning to balance accuracy and reduce false positives. This tuning process is often complex and ongoing, as it must adapt to an organization's specific environment and evolving threat landscape.

To enhance detection capabilities, some IDS solutions combine signature-based and anomaly-based methods, creating a hybrid model that can detect both known and unknown threats. These IDS can operate in either a stateless or stateful manner. Stateless IDS analyze individual packets independently, while stateful IDS track entire network flows to provide better context for threat detection. Modern IDS implementations increasingly favor stateful approaches, as they offer deeper insights into traffic patterns and attack behaviors.

The table below outlines the key differences between signature-based and anomaly-based IDS structures:

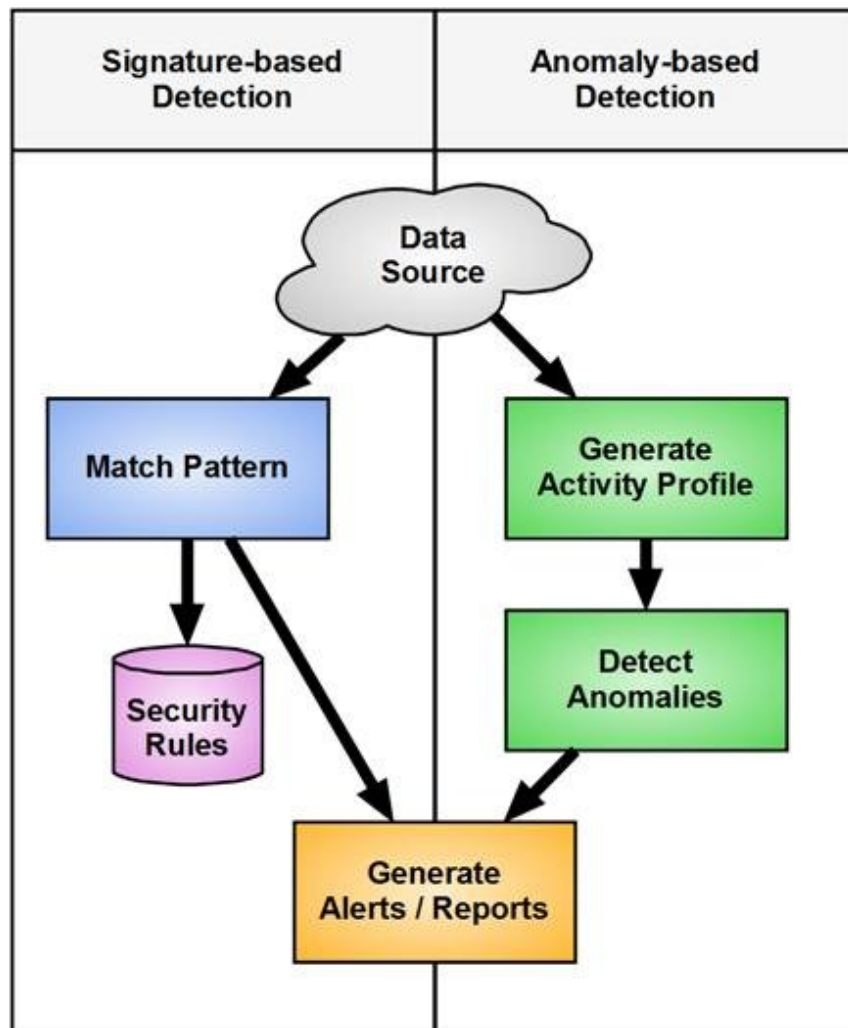


Figure 0.5: Signature and Anomaly based

0.3.2 Other Detection Methods

Some less common detection techniques include:

- **Reputation-based:** Blocks traffic from IP addresses and domains with poor reputation scores based on historical threat intelligence.
- **Stateful protocol analysis:** Detects protocol-based anomalies, such as denial-of-service (DoS) attacks that exploit TCP/IP protocol vulnerabilities.

0.4 IDS Evasion Techniques

Despite their effectiveness, Intrusion Detection Systems are not infallible. Sophisticated attackers employ various techniques to circumvent IDS detection. Understanding these evasion techniques is crucial for organizations to strengthen their security posture and implement appropriate countermeasures. Some common IDS evasion methods:

- **Distributed denial-of-service (DDoS):** An Intrusion Detection System (IDS)

operates as either a dedicated network device or software running on a computer, leaving it susceptible to attacks aimed at disabling its protective features. In a typical scenario, a threat actor who has successfully breached the system will first quickly try to deactivate the IDS to avoid detection while targeting the broader network. A common Distributed Denial of Service (DDoS) tactic involves flooding the IDS with spoofed User Datagram Protocol (UDP) and Internet Control Message Protocol (ICMP) traffic [3]. This traffic is designed to look obviously malicious, thus overwhelming the IDS's processing capacity. As the IDS struggles to handle these fake threats, attackers can exploit this distraction to execute their actual attacks undetected. This technique effectively creates a smokescreen of activity that conceals the real intrusion attempt.

To address this, there is a need to implement IDS in stealth mode. In this configuration, the IDS operates with two network interfaces:

- A monitoring interface that passively observes network traffic without interacting with it. This interface operates with a hidden address that is not published anywhere, not even to internal routers. It simply allows packets to pass through while recording activity.
- A separate alert interface that operates on an entirely different network. When the IDS detects suspicious activity, it uses this second interface to issue alerts and warnings to the security team.

This dual-interface design significantly enhances IDS resilience against direct attacks, as attackers cannot easily identify and target the monitoring components of the system.

- **Spoofing:** Spoofing techniques involve falsifying IP addresses and DNS records to make malicious traffic appear to originate from trusted sources. By impersonating legitimate entities, attackers can bypass IDS rules that might otherwise flag suspicious traffic from unknown origins. This technique exploits the trust relationships established within networks. For example, an attacker might spoof the IP address of a trusted internal server to gain unauthorized access to sensitive data or resources.
- **Fragmentation:** Fragmentation involves splitting malicious payloads into smaller packets to obscure their signatures and evade detection. By strategically delaying packet transmission or sending packets out of sequence, attackers can prevent the IDS from properly reassembling and analyzing the complete payload. When the IDS cannot reconstruct the fragmented packets

correctly, it fails to recognize the attack pattern.

- **Packet Encoding:** Encoding packets using methods such as Base64 or hexadecimal representation can effectively hide malicious content from signature-based IDS solutions. These encoding techniques transform the data in ways that may not match known attack signatures while preserving the payload's functionality when executed at the destination. By encoding malicious payloads, attackers can bypass signature-based detection and deliver harmful content to target systems.
- **Traffic Obfuscation:** Obfuscation techniques make network traffic difficult to interpret, thereby concealing attacks from detection systems. The process involves altering program code or network traffic in ways that maintain functional equivalence while significantly reducing readability and detectability. Obfuscated malware, for instance, can bypass IDS detection while retaining its malicious capabilities. The objective is to reduce detectability to reverse engineering or static analysis process by obscuring it and compromising readability. Obfuscating malware, for instance, allows it to evade IDSes.
- **Encryption:** Encrypted protocols present a significant challenge for many IDS solutions. If the IDS does not possess the corresponding decryption keys or capabilities to inspect encrypted traffic, attackers can use encryption to transmit malicious payloads without detection. As encryption becomes more widespread for legitimate traffic, this technique becomes increasingly effective.
- **Operator fatigue:** Attackers may deliberately generate large volumes of IDS alerts by performing non-threatening but unusual actions across the network. This approach creates "operator fatigue," overwhelming security teams with false positives and distracting them from identifying and responding to actual malicious activities occurring simultaneously.

0.5 IDS Integration with Other Security Tools

IDSs are not standalone tools. They are designed to be part of a holistic cyber security system, and are often tightly integrated with one or more of the following security solutions. Therefore, they can sometimes be confused with these other tools. Here's a quick overview of how IDSs differ from these other security solutions:

a, IDS vs. IPS

While Intrusion Detection Systems (IDS) and Intrusion Prevention Systems (IPS) share similar detection capabilities, they differ significantly in their response mechanisms and network placement.

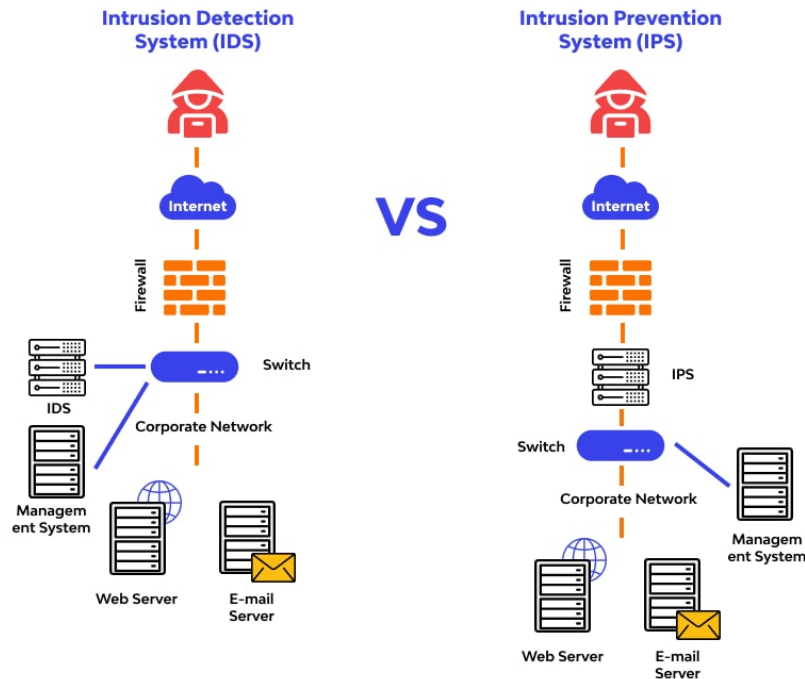


Figure 0.6: IDS (left) vs IPS (right)

Table 4 highlights these key differences.

Table 4: Comparison of IDS and IPS Characteristics

Characteristic	Intrusion Detection System (IDS)	Intrusion Prevention System (IPS)
Placement in Network	Out-of-band (outside direct communication path)	Inline (part of direct communication path)
System Type	Passive (monitor and notify)	Active (monitor and automatically defend)
Response Capability	Detection only; cannot prevent exploits	Detection and automatic prevention
Traffic Impact	Minimal impact on network performance	Can potentially affect network throughput
Detection Mechanisms	Primarily signature-based detection	Both signature-based and anomaly-based detection

An IDS operates as a listen-only device that monitors traffic and reports findings to administrators but cannot independently take action to prevent detected exploits.

In contrast, an IPS can automatically respond to threats by blocking malicious traffic, resetting connections, or taking other preventative measures.

Many modern organizations implement both capabilities within a single Intrusion Detection and Prevention System (IDPS), which combines detection, logging, alerting, and automated response functions.

0.5.1 IDS vs. Firewall

While firewalls and IDS serve different primary functions, they work together to create a more robust security posture. Most security mechanisms previously discussed, such as user authentication and firewalls, focus on preventing attacks from external sources. However, a significant percentage of documented destructive attacks originate internally, either from malicious users or from external attackers who have successfully penetrated these protective barriers.

How firewall benefit from IDS

Firewalls serve as the first layer of protection, functioning as access control barriers by using predefined rule sets to permit or block traffic based on source, destination, protocol, and port information. They actively filter traffic but may not detect sophisticated attacks that conform to allowed traffic patterns.

In contrast, an IDS monitors traffic that has already passed through the firewall, detecting suspicious activities that might indicate an attack in progress. While firewalls reject traffic that violates security rules, they cannot detect attacks originating from within the network or those disguised as legitimate traffic—scenarios where an IDS proves invaluable.

Why they are better together ?

- IDS helps firewalls: Catches sneaky attacks that slip past firewall rules, providing feedback to improve firewall policies over time.
- Firewalls help IDS: By blocking obvious threats (e.g., spam or port scans), firewalls reduce "noise," letting the IDS focus on complex analysis instead of getting overwhelmed by easily blocked traffic (e.g., port scans).

The complementary relationship between these technologies can be understood through an analogy: A firewall is like a security checkpoint controlling entry, whereas an IDS functions like surveillance cameras inside the premises, analyzing activities post-entry.

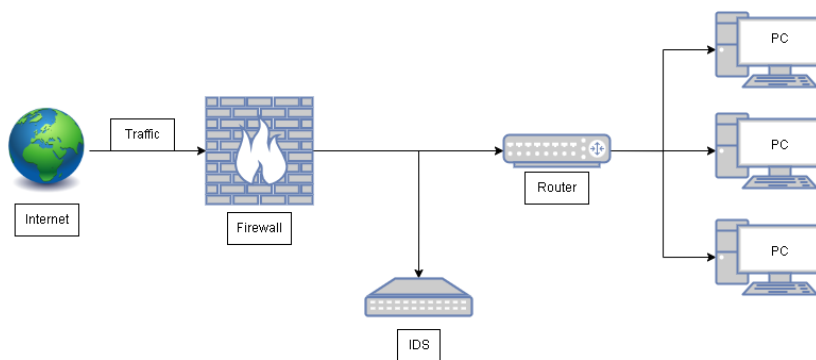


Figure 0.7: Firewall and IDS in a network

In a home lab environment, a common open-source setup often consists of a combination of Snort or Suricata (IDS) and pfSense (firewall).

0.5.2 IDS and SIEM

An IDS acts as a watchful guard, scanning network traffic in real time to spot suspicious activity, such as malware signatures or unusual data flows. Meanwhile, a SIEM system operates like a central command center, collecting and analyzing data from every corner of an organization's infrastructure—firewalls, servers, applications, and even the IDS itself. Together, they bridge the gap between real-time detection and holistic threat analysis.

Why they are better together ?

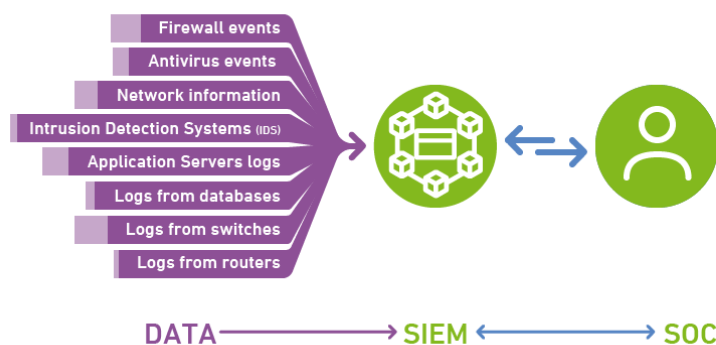


Figure 0.8: IDS as a data source of SIEM

- **SIEM Enhances IDS:** A SIEM adds critical context to IDS alerts. For example, if an IDS flags a sudden surge in data transfers, the SIEM cross-references this event with user authentication logs, geographic IP data, and historical patterns to determine whether it's a legitimate backup process or a potential data breach. It also automates responses, such as quarantining a compromised device, and stores long-term data to identify trends (e.g., recurring attack pat-

terns) that an IDS might overlook in the moment.

- **IDS Enhances SIEM:** The IDS feeds real-time threat data into the SIEM, acting as its "eyes and ears" on the network. This allows the SIEM to prioritize alerts more effectively—for instance, distinguishing harmless network noise from a coordinated brute-force attack. The IDS also detects subtle anomalies, like encrypted traffic hiding malicious payloads, which the SIEM can then correlate with other events (e.g., unusual login times or privileged account activity) to uncover advanced threats.

In practical, some integrated Solutions like Security Onion bundle IDS tools (Suricata, Zeek) with SIEM capabilities (Elastic Stack) for an all-in-one network monitoring suite.

0.5.3 IDS and Honeypots

Intrusion Detection Systems (IDS) and honeypots serve distinct but complementary roles in cybersecurity. While an IDS monitors real network traffic for signs of malicious activity, honeypots act as bait designed to attract attackers and reveal their tactic. These intelligent can be used to strengthen IDS real-time defense Together, they create a more robust security posture that combines detection with active threat intelligence gathering.

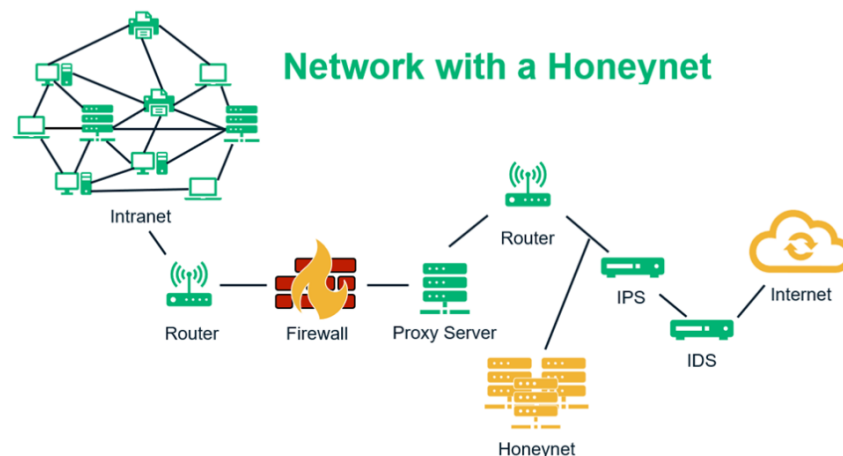


Figure 0.9: IDS combines with Honeypots within a network

Honeypots provide several key benefits to IDS operations:

- They reduce false positives by offering unambiguous evidence of malicious intent - any interaction with a decoy system warrants investigation
- They serve as early warning systems, often detecting attack reconnaissance long before critical systems are targeted
- They provide safe environments for IDS to study about emerging threats with-

out risking real production assets.

In practice, security teams often deploy honeypots in strategic network segments - near critical assets, in DMZs, or in seemingly neglected areas that might attract attackers. When integrated with an IDS, any activity detected in these honeypots can trigger enhanced monitoring of related network segments or specific security controls. Some practical integration can be tools like T-Pot (honeypot suite) and Suricata (IDS) work in tandem.

0.6 Some Popular IDS/IPS In The Industry

- **Snort**

- **Ownership and History:** Owned by Cisco, Snort was first released in 1998, making it one of the earliest open-source IDS/IPS tools. It gained prominence through its acquisition by Sourcefire, which Cisco later acquired in 2013.
- **Technical Details:** Snort operates as a network-based IDS/IPS, using a rule-based language for signature-based detection. It supports real-time traffic analysis, packet logging, and can be configured as a sniffer, logger, or full intrusion prevention system. Its community ruleset and subscriber ruleset enhance its detection capabilities.
- **Use Case:** Widely used for monitoring network traffic, detecting known threats like buffer overflows and stealth port scans, and integrating with SIEM systems for broader analysis. See more detail about Snort via this [link](#)

- **Suricata**

- **Ownership and History:** Developed by the Open Information Security Foundation (OISF), Suricata was first released in beta in 2009, with a standard release in 2010. It is maintained by a global community, emphasizing open-source collaboration.
- **Technical Details:** A network-based IDS/IPS, Suricata offers multi-threaded performance for high-speed traffic analysis, featuring multi-threaded architecture, GPU acceleration, deep packet inspection, and file extraction. It supports both signature-based and anomaly-based detection, making it a robust alternative to Snort. Suricata is compatible with Snort rules, making migration seamless.
- **Use Case:** Ideal for enterprises needing high-performance network security monitoring, with integration capabilities for tools like Wazuh for

enhanced endpoint visibility. See more detail about Suricata via this link

- **Zeek**

- **Ownership and History:** Formerly known as Bro, originating in 1995 at Lawrence Berkeley National Lab under Vern Paxson, Zeek is now maintained by the Zeek community. It is known for its long history in network security monitoring.
- **Technical Details:** Zeek is a network-based security monitor, not a traditional IDS, focusing on log generation and scriptable analysis. It supports semantic misuse detection, anomaly detection, and behavioral analysis, with over 70 default log files and 3,000+ network events tracked.
- **Use Case:** Used by universities, research labs, and enterprises for detailed network traffic analysis, often integrated with SIEM systems for incident response. See more detail about Zeek via this link

- **OSSEC:**

- **Ownership and History:** Created by Daniel B. Cid in 2003, OSSEC is now managed by Atomicorp, a company providing additional support and commercial versions. It was acquired by Third Brigade in 2008, with open-source version is popular for small teams, while Atomic OSSEC offers enterprise scalability.
- **Technical Details:** A host-based IDS, OSSEC focuses on log analysis, file integrity monitoring, Windows registry monitoring, rootkit detection, and active response. It runs on multiple platforms, including Linux, Windows, and MacOS, with a centralized architecture for distributed monitoring.
- **Use Case:** Suitable for organizations needing endpoint security, compliance auditing (e.g., PCI-DSS, HIPAA), and real-time alerting for host-level threats.. See more detail about OSSEC via this link

- **Wazuh**

- **Ownership and History:** Released in 2018 as a fork of OSSEC, Wazuh is maintained by Wazuh Inc., offering both free and paid services to users. It has grown in popularity, with thousands of enterprise users.
- **Technical Details:** Primarily host-based, Wazuh provides log analysis, file integrity monitoring, vulnerability detection, and incident response. It integrates with network IDS like Suricata for broader coverage, offer-

ing SIEM and XDR capabilities. It also integrates with Elasticsearch for visualization and supports cloud, on-premises, and hybrid environments. Wazuh is known for its lightweight agents and automated threat response.

- **Use Case:** Used for endpoint protection, cloud workload monitoring, and compliance, with flexible deployment options for on-premise and cloud environments. See more detail about Wazuh via [this link](#)

- **Security Onion**

- **Ownership and History:** Created by Doug Burks in 2008, Security Onion is maintained by Security Onion Solutions, with over 2 million downloads. It is a Linux distribution based on Ubuntu, designed for security professionals.
- **Technical Details:** Combines network and host-based tools, including Snort, Suricata, Zeek, Wazuh, and others, for intrusion detection, network security monitoring, and log management. It uses the Elastic Stack for analysis, Sguil for alert management, Kibana for dashboards and offers full packet capture via netsniff-ng. Ideal for centralized intrusion detection and log analysis.
- **Use Case:** Ideal for enterprises needing a scalable, open-source platform for distributed sensor grids, used in home offices, governments, and Fortune 500 companies. See more detail about Security Onion via [this link](#).

- **Cisco Secure IDS**

- **Ownership and History:** Owned by Cisco, with roots in the 1990s, Cisco Secure IDS has evolved into the Cisco Secure Firewall, which includes IPS features. It is part of Cisco's broader security portfolio, leveraging Cisco Talos for threat intelligence.
- **Technical Details:** Network-based, it uses signature databases for intrusion detection, now integrated with firewall capabilities for inline prevention. It offers simplified configuration and real-time event reporting.
- **Use Case:** Suitable for large enterprises needing integrated network security. See more detail via [this link](#).

- **IBM QRadar IDS**

- **Ownership and History:** Developed by Q1 Labs in 2007, acquired by IBM in 2011, QRadar is a commercial SIEM platform, recognized as a leader in the 2024 Gartner Magic Quadrant for SIEM for the 14th consec-

utive time.

- **Technical Details:** Primarily a SIEM, it integrates with IDS/IPS for log collection, event correlation, and threat prioritization using AI and machine learning. It supports federated search across cloud and on-premises data.
- **Use Case:** Used for centralized security management, compliance, and incident response, with a focus on reducing noise and enhancing SOC analyst productivity. See more detail about IBM QRadar IDS via this link.

- **McAfee Network Security Platform, now Trellix:**

- **Ownership and History:** Originally part of McAfee, with significant developments around 2010, it became part of Trellix following the merger with FireEye in 2021. Trellix focuses on integrated cybersecurity solutions.
- **Technical Details:** Network-based, it offers next-generation IPS with signature-less technologies, machine learning for real-time threat detection, and fail-open capabilities for high availability.
- **Use Case:** Suitable for organizations needing advanced threat protection, with integration into broader security ecosystems for comprehensive defense. See more detail about McAfee via this link.

- **Trend Micro TippingPoint**

- **Ownership and History:** Founded in 1999 as TippingPoint Technologies, acquired by Trend Micro in 2015, it is part of Trend Micro's network security offerings, with a focus on real-time threat protection.
- **Technical Details:** Network-based, it uses deep packet inspection, threat reputation, URL reputation, and machine learning for detecting and blocking malicious traffic. Renowned for its Digital Vaccine® threat intelligence, offering real-time vulnerability protection and automated virtual patching. Excels in high-availability environments with fail-safe bypass mechanisms. Integrates with Trend Micro's Vision One platform.
- **Use Case:** Ideal for enterprises needing proactive network security, with flexible deployment options and centralized management. See more detail about Trend Micro via this link.

Summary Table: [4]

Name	Company Owned	Year	Open-source	Primary Focus	Cost
Snort	Cisco	1998	Yes	Network-based	Free, subscription (\$30/yr personal, \$300/yr business)
Suricata	OISF	2010	Yes	Network-based	Free (GPL v2 license)
Zeek	Community	1995	Yes	Network-based	Free*
OSSEC	Atomicorp	2003	Yes	Host-based	Free, \$5/agent/-month for commercial version
Wazuh	Wazuh Inc.	2018	Yes	Host-based	Free (open-source), commercial support available
Security Onion	Security Onion Solutions	2008	Yes	Both	Free*
Cisco Secure IDS	Cisco	1990s	No	Network-based	Starts at \$5,000 (varies by model)
IBM QRadar	IBM	2007	No	SIEM	Contact vendor (based on events per second)
McAfee Network Security	Trellix	2010	No	Network-based	\$10,995+
Trend Micro TippingPoint	Trend Micro	1999	No	Network-based	Contact vendor for pricing

Table 5: Summary Table of IDS/IPS Solutions

**Support or preloaded appliances available from 3rd party vendors for a fee.
All pricing data is collected as of March 31, 2025*

In the following chapters, we will explore Suricata in detail, including installation, configuration, and set up a lab environment.